

MODULE 09 · DOMAIN 2 - SECURITY AND COMPLIANCE

Compliance and Governance

Setting boundaries across many accounts, and proving you did.

DOMAIN 2 of 4 EXAM WEIGHT 30% MODULE 9 of 26

Governance sets the **boundary**.
Compliance produces the **evidence**.

AWS Organizations

- ◆ **Centrally manage many AWS accounts** as one organisation. The service itself is free.
- ◆ **Consolidated billing** gives one bill, and aggregates usage so volume discounts apply across all accounts.
- ◆ Organizational units group accounts so policies can be applied to a whole group at once.
- ◆ **One management account** pays the bill. All others are member accounts.
- ◆ Several services, including Firewall Manager and Control Tower, require Organizations to exist first.

ON THE EXAM

Consolidated billing aggregating usage for volume discounts is a Domain 4 favourite. It lives here too.

Service control policies

- ◆ **An SCP sets the maximum permissions available** in an account. It is a ceiling.
- ◆ An SCP never grants anything. A user still needs an IAM policy allowing the action.
- ◆ **An action succeeds only if the SCP allows it and an IAM policy allows it.** Both, not either.
- ◆ SCPs bind even the root user of a member account, which IAM policies cannot do.
- ◆ SCPs do not apply to the management account. That account is never restricted by them.

ON THE EXAM

Ceiling, not grant. If an option says an SCP gives users permission to do something, it is wrong.

SCP or IAM policy?

SERVICE CONTROL POLICY

What is possible in the account

- Attached to an OU or account
- Restricts; never grants
- Applies to every identity, including root
- Requires AWS Organizations

IAM POLICY

What this identity may do

- Attached to a user, group or role
- Grants and denies
- Applies to that identity only
- Works in a standalone account

THE TIEBREAKER

Restrict what an entire account can do means SCP. Give this person access means IAM.

The other Organizations policy types

- ◆ **Tag policies** enforce consistent tagging standards across accounts.
- ◆ **Backup policies** centrally manage backup plans for resources across the organisation.
- ◆ **Resource control policies**, added in late 2024, set a ceiling on what can be done to a resource.
- ◆ **Declarative policies**, also from late 2024, enforce a baseline configuration for EC2, EBS and VPC.
- ◆ The exam guide names service control policies only. The last two are beyond CLF-C02.

ON THE EXAM

You will see four policy types in the console. Only SCPs are examinable. Recognising the others is enough.

AWS Control Tower

- ◆ **It sets up a multi-account landing zone** using Organizations, IAM Identity Center, CloudTrail and Config.
- ◆ **Controls, previously called guardrails**, come in three kinds: preventive, detective and proactive.
- ◆ Account Factory provisions new accounts already conforming to the standard.
- ◆ Preventive controls are implemented with SCPs. Detective controls are implemented with Config rules.
- ◆ It builds on Organizations rather than replacing it. Organizations must exist underneath.

ON THE EXAM

Control Tower is the opinionated setup. Organizations is the raw capability it is built on.

Organizations or Control Tower?

AWS ORGANIZATIONS

The building blocks

- Accounts, OUs, SCPs, consolidated billing
- You design the structure yourself
- Maximum flexibility
- Nothing is configured for you

AWS CONTROL TOWER

Best practice, pre-assembled

- A landing zone built to AWS recommendations
- Controls switched on by default
- Account Factory for new accounts
- Less flexible, far quicker to reach

THE TIEBREAKER

Quickly set up a secure multi-account environment means Control Tower. Manage accounts and apply SCPs means Organizations.

AWS Service Catalog

- ◆ **A curated list of approved products** that users can launch themselves.
- ◆ Central teams define what is approved. Users deploy without needing broad permissions.
- ◆ Products are CloudFormation templates, so what gets deployed is consistent every time.
- ◆ **It solves the tension between self-service and control.**
- ◆ It is not a marketplace. AWS Marketplace sells third-party software; Service Catalog lists your own approved items.

ON THE EXAM

Approved, pre-configured, self-service and consistent all point at Service Catalog.
Buying third-party software points at Marketplace.

Who checks what

SERVICE	CHECKS AGAINST
AWS Config	Rules you enable or write. Your definition of compliant.
AWS Trusted Advisor	AWS best practices. Cost, performance, security, fault tolerance, quotas.
AWS Security Hub	Security standards such as CIS and PCI DSS, plus other services' findings.
AWS Control Tower	Its own controls, applied continuously across the landing zone.

ON THE EXAM

All four tell you something is wrong. The difference is whose standard they are measuring you against.

AWS Artifact

- ◆ **Self-service download of AWS compliance reports.** SOC, ISO, PCI and many others.
- ◆ This is how you evidence AWS's half of the shared responsibility model to an auditor.
- ◆ **It also holds agreements** you can review and accept, such as a Business Associate Addendum.
- ◆ It audits nothing. It is a document repository, and that is the whole service.
- ◆ AWS Audit Manager is a different service, and it is not on the CLF-C02 in-scope list.

ON THE EXAM

An auditor asking for proof of AWS's controls means Artifact. You cannot inspect a data centre yourself.

Where the logs actually live

LOG	WHAT IT RECORDS
AWS CloudTrail	API calls and account activity. Who did what.
Amazon CloudWatch Logs	Application and operating system logs you send to it.
VPC Flow Logs	IP traffic going to and from network interfaces.
S3 server access logs	Requests made to objects in a bucket.
AWS Config	Configuration state over time. Not strictly a log, but the history.

ON THE EXAM

Who did it is CloudTrail. What the network saw is Flow Logs. What the application printed is CloudWatch Logs.

A company has ninety AWS accounts under AWS Organizations. Policy states that no account outside the research organizational unit may launch resources in Regions outside the European Union, regardless of who is asking.

Several accounts have their own administrators with full IAM permissions.

How should the company enforce this?

- ☐ A Attach an IAM policy denying other Regions to every user
- ☐ B Apply a service control policy to the relevant organizational units
- ☐ C Create an AWS Config rule that flags resources in other Regions
- ☐ D Use AWS Trusted Advisor to report on Region usage

◆ PAUSE AND DECIDE

How should the company enforce this?

- A

 Attach an IAM policy denying other Regions to every user
A local administrator with full IAM permissions can simply detach it. It does not survive the stated conditions.
- B

 Apply a service control policy to the relevant organizational units
Sets a ceiling that no identity in those accounts can exceed, including local administrators and root.
- C

 Create an AWS Config rule that flags resources in other Regions
Detects the violation after it happens. The requirement is that it cannot happen.
- D

 Use AWS Trusted Advisor to report on Region usage
Reporting, not enforcement. It also does not check against your own policy.

THE SIGNAL

Regardless of who is asking, plus local administrators with full IAM. Only a ceiling above IAM satisfies both.

A healthcare provider's auditor requests evidence that the physical and environmental controls at the data centres hosting its workloads meet SOC 2 requirements. The provider also needs to sign a Business Associate Addendum with AWS.

The provider has no ability to visit or inspect any AWS facility.

Which service should the provider use?

- | | |
|---|---|
| ☐ A AWS Config | ☐ B AWS Artifact |
| ☐ C AWS Security Hub | ☐ D AWS CloudTrail |

◆ PAUSE AND DECIDE

Which service should the provider use?

- A

AWS Config
Reports on your resource configuration. It has no visibility of AWS's own controls.
- B

AWS Artifact
Holds AWS's SOC and ISO reports, and the agreements including the Business Associate Addendum. Both requirements.
- C

AWS Security Hub
Measures your account against standards. It does not supply AWS's own audit reports.
- D

AWS CloudTrail
Records your API activity. Nothing to do with data centre controls.

THE SIGNAL

Physical controls plus a signed agreement. Both live in Artifact, and neither is visible from your account.

A company is about to expand from one AWS account to roughly thirty. It wants a secure multi-account environment quickly, with a standard set of controls applied from the start, centralised logging, and a repeatable way for teams to request new accounts. It has no existing multi-account design and limited time to create one.

Which service should the company use?

- ☐ A AWS Organizations alone, with hand-written SCPs
- ☐ B AWS Control Tower
- ☐ C AWS Service Catalog
- ☐ D AWS Config with conformance packs

◆ PAUSE AND DECIDE

Which service should the company use?

- A

 AWS Organizations alone, with hand-written SCPs
Would work eventually, but the company must design everything itself. The stem rules that out on time.
- B

 AWS Control Tower
Landing zone, controls, centralised logging and Account Factory. All four requirements in one service.
- C

 AWS Service Catalog
Curated products teams can launch. It does not create or govern accounts.
- D

 AWS Config with conformance packs
Detects non-compliance. It builds no accounts and establishes no environment.

THE SIGNAL

Quickly, from the start, and a repeatable way to request accounts. Account Factory is the deciding capability.

A platform team wants development squads to be able to deploy pre-approved, correctly configured environments on demand, without giving those squads permission to create arbitrary resources.

Separately, the security team wants an alert whenever any deployed resource drifts from the required encryption settings.

Which two services meet these requirements? (Choose two.)

- | | |
|--|--|
| ☐ A AWS Service Catalog | ☐ B AWS Marketplace |
| ☐ C AWS Config | ☐ D AWS Artifact |
| ☐ E AWS Trusted Advisor | |

◆ PAUSE AND DECIDE

Which two services meet these requirements? (Choose two.)

- A

AWS Service Catalog
Pre-approved products squads can launch themselves, without broad permissions. Exactly the first requirement.
- B

AWS Marketplace
Sells third-party software. These are the company's own approved environments, not purchases.
- C

AWS Config
Rules evaluate resource configuration continuously and report drift from a required setting.
- D

AWS Artifact
AWS's compliance reports. It reports nothing about your own resources.
- E

AWS Trusted Advisor
AWS best-practice checks, not your specific encryption standard. The wrong standard.

THE SIGNAL

Self-service within limits is Service Catalog. Drift from your own required setting is Config, not Trusted Advisor.

What to carry out of this module

- ◆ **Governance prevents. Compliance proves.** Read which one the question wants.
- ◆ **An SCP is a ceiling, never a grant.** The action needs both an SCP allow and an IAM allow.
- ◆ SCPs bind the root user of a member account. They never bind the management account.
- ◆ Control Tower is the quick opinionated landing zone. Organizations is the raw capability underneath.
- ◆ **Artifact is where AWS's own audit reports live.** It is a repository, not an auditing service.

ON THE EXAM

Config checks your rules. Trusted Advisor checks AWS's best practices. Whose standard is it? That decides.